대외비 2급

정보보안 감사 지침서

2012. 02

연세대학교 의료원
YONSEI UNIVERSITY HEALTH SYSTEM

제 개정 이력

제 개정번호	일자	제 개정 내용 요약	작성자
2012-01	2012-02-22	ISO27001 인증 대비 전면 개정	조남인
2016-01	2016-09-26	위원회 명칭 변경 (정보보호 위원회)	조남인
2016-02	2017-01-16	외부 안전진단 삭제 산하기관장 승인 하 감사 실시 여부 추가	조남인
2020-01	2020-11-04	제5조 (대상범위) 수정	조남인
2023-01	2024-01-08	제4조(책임과 역할)	조남인
2024-01	2024-04-24	제10조, 제11조 승인권자 변경 (의료원장 → 최고정보보호책임자)	조남인

목 차

제1조 (목적)..... 3

제2조 (적용범위)..... 3

제3조 (용어의 정의)..... 3

제4조 (책임과 역할)..... 3

제5조 (대상범위)..... 4

제6조 (감사시기)..... 5

제7조 (감사인의 독립과 의무)..... 5

제8조 (감사인의 권한)..... 5

제9조 (감사인의 조직)..... 5

제10조 (감사의 실시)..... 6

제11조 (감사보고서의 작성과 보고)..... 6

제12조 삭제 <2017.01.16>..... 7

제13조 (감사결과에 의한 업무개선)..... 7

제14조 (시스템 감사도구에 대한 보호)..... 7

제15조 (시행과 갱신)..... 8

제1조 (목적)

본 지침서는 연세대학교 의료원(이하 산하기관을 포함하여 '의료원'이라 칭함)의 시스템 보안을 유지 관리하는 데 도움이 되는 가장 강력한 도구 중 하나로서 연세대학교 의료원(이하 '의료원'이라 칭함)의 정보보호 관련 지침서 준수여부에 대한 감사 기준 및 절차와 정보보호관리체계 인증을 유지하는데 기여하는 것을 목적으로 한다.

제2조 (적용범위)

의료원 내의 정보보호규정 및 지침에 규정된 사항의 이행여부를 확인하기 위한 모든 활동을 적용범위로 하며, 감사인 및 피 감사인, 모든 시스템을 대상으로 한다.

제3조 (용어의 정의)

① "감사인"이란 감사부문에 소속되고, 정보보호와 개인정보보호의 감사업무를 담당하는 자를 말한다.

② "피 감사부문"이란 정보보호 및 개인정보보호 관련지침서에 기초하여 개인정보 취급을 시행하는 등 감사를 받고 있는 조직을 말한다.

③ "지적사항"이란 감사 결과 감사자가 문제가 있다고 판단한 사항을 말한다.

④ "개선권고"란 지적사항 중 피 감사부문에서 개선이 필요하다고 판단되는 사항을 말한다. 이 중에서 긴급성을 필요로 하는 사항은 긴급개선, 그 외의 사항은 통상개선으로 권고한다.

제4조 (책임과 역할)

① 최고정보보호책임자 : 의료의 정보시스템 총괄 책임자로서 의료원 정보보호와 개인정보보호 책임자 역할을 겸직 수행하며 정보보호 감사 계획을 승인하고 정보보호 감사 업무를 총괄한다.

② 정보보호책임자 : 최고정보보호책임자에 의해 위임된 정보보호 업무를 수행한다.

③ 정보보호감사관 : 감사업무 주관 부서장으로서 감사업무를 총괄 하며 보안감사 시 정보보호실무책임자와 협의하여 수행한다.

④ 정보보호관리자(각 부서장) : 각 부서장으로서 부서의 정보보호와 개인정보보호를 직접 수행하며 부서 보안사고에 대한 책임을 지며 피 감사부서로 정보보호 감사에 적극적으로 협조해야 하며 지적사항에 대해 개선방안을 수립하고 사후관리를 수행한다.

⑤ 정보보호실무책임자 : 정보보호 주관 부서장으로서 전사적인 정보보호와 개인정보보호 정책 수립 및 이행하며 정보보호관리자(각 부서장)의 정보보호 활동을 지원하며, 정보보호 감사 주관 부서장으로서 정보보호감사 계획을 수립하여 이행하며 피 감사부서의 지적사항에 대한 사후관리를 지속적으로 수행한다.

⑥ 정보보호 및 보안 실무담당자 : 정보보호실무책임자가 임명한 정보보호 및 개인정보보호 업무 담당자로서 의료원 정보보호 및 개인정보보호를 위한 관리적/물리적/기술적 부문에서 각 부서의 관련 제반 업무를 지원하며 본 지침서의 이행 점검을 수행한다.

⑦ 부서 정보보호담당자 : 정보보호관리자(각 부서장)가 임명한 부서의 정보보호담당자로서 의료원 정보보호 정책이 이행될 수 있도록 부서 내에서 정보보호 업무를 성실히 수행한다.

⑧ 사용자 : 직번 계정(ID)과 도메인 계정(AD)을 부여 받아 정보시스템에서 제공하는 서비스를 이용하여 업무를 처리하거나 정보를 획득하는 자로서 의료원 교직원 뿐 아니라, 파견업체나 협력업체 등 외부자를 포함하며, 사용자는 의료원의 정보자산을 보호하고, 정보보호 규정 및 지침서를 성실히 준수해야 할 의무를 갖는다.

제5조 (대상범위)

① 감사 대상은 다음과 같다.

1. 정보시스템 : 개인정보를 처리하는 모든 정보시스템
2. 업무 : 직무분장지침서에 의거 개인정보를 취급하는 전 업무
3. 부서 : 직무분장지침서에 의거 개인정보를 취급하는 전 관련부서

제6조 (감사시기)

① 감사 실시 시기는 다음과 같다.

1. 정기감사 : 연간 감사계획에 의한 일정 기간마다 시행
2. 삭제 <2017.01.16>
3. 수시감사 : 필요에 의한 수시 시행

제7조 (감사인의 독립과 의무)

① 감사인은 객관적 업무수행을 위해 감사대상에서 독립되어야 하며, 피 감사 주체와 신분상의 밀접 이해관계를 가져서는 안 된다.

② 감사인은 객관성과 공정성을 기하고, 편향적이지 않게 판단할 수 있어야 한다.

③ 감사인은 업무상 취득한 비밀에 대하여 정당한 이유 없이 타인에게 제공하거나 개인의 이익을 위해 이용해서는 안 된다.

④ 감사인은 직업윤리에 따라 성실하게 업무수행을 하여야 한다.

⑤ 감사인은 정당한 이유 없이 감사 실시로 인해서 알게 된 비밀을 유출하고, 부정한 목적에 사용해서는 안 된다.

⑥ 모든 항의 지침서는 인사발령에 의하여 직무가 변경된 후에도 존속한다.

제8조 (감사인의 권한)

① 감사인은 부서별 감사계획에 근거한 감사 실시에 있어서 피 감사부문에게 자료 제공을 요구할 수 있다.

② 감사인은 개선권고에 기초하여 경영자가 피 감사부문에게 개선을 명령한 사항에 있어서는 해당부서에 실시상황 보고를 요구할 수 있다.

제9조 (감사인의 조직)

① 감사인은 감사의 목적이 원활하고 효율적으로 달성될 수 있도록 체계를 정비하고, 계획의 입안에서 결과보고서의 제출 및 개선지도까지의 모든 업무를 관장한다.

② 감사인은 감사업무의 목적달성에 필요하다고 판단이 되는 경우 내·외부 전문가에게 지원요청을 고려하여야 하며, 이러한 경우 이용범위와 방법, 결과의 판단은 감사인의 책임하에 이루어 진다.

③ 정보보호실무책임자는 최고정보보호책임자의 승인을 득하여 정보보호감사관과 협의하여 인사, 총무, 정보통신, 개인정보 등 다양한 실무담당자로 감사 조직을 구성하여 정기 감사나 수시 감사 때 정보보호 감사를 수행할 수 있다.

제10조 (감사의 실시)

① 감사인은 회계연도 초에 감사계획서를 작성하여 최고정보보호책임자의 승인을 받아야 하며, 긴급한 감사의 필요성이 발생 할 시는 예외로 한다.

② 감사인은 결정된 감사계획서를 해당부서로 통보하며, 부서별 실시계획은 별도 수립한다.

③ 감사인은 부서별 계획서에 의하여 예비조사, 본 조사 및 평가, 결론의 순서에 의하여 업무를 진행한다.

1. 예비조사 : 감사대상의 현상에 대한 문제점 파악
2. 본 조사 : 평가 목적의 근거가 되는 구체적 자료 수집
3. 평가, 결론 : 평가의 척도를 명확하게 할 것

④ 감사인은 감사계획에 근거하여 적절하고 신중하게 감사 절차를 실행하며, 감사결과를 입증하는데 충분한 감사증거를 입수하여 평가한다.

⑤ 감사인은 감사 절차 및 결과 등의 관련자료에 근거하여 감사조서를 작성하며, 감사조서는 감사결과 도출과정이 명확히 나타날 수 있도록 기술한다.

⑥ 산하기관은 해당 기관장의 승인을 받아 별도 감사를 실시할 수 있다.

⑦ 정보보호실무책임자는 기술적 취약성 진단 수행 시 취약성 분석도구를 사용할 수 있다.

제11조 (감사보고서의 작성과 보고)

① 감사인은 감사보고서를 작성하기 전 피 감사 부서 관계자와의 강평회를 실시하며, 이를 통하여 문제점에 대한 사실 오인여부를 확인한다.

② 감사인은 다음사항들에 대하여 감사목적에 맞도록 명료하게 기재한다.

1. 감사의 대상
2. 감사실시 개요
3. 보증 또는 조언관련 의견
4. 제약 또는 제외 사항
5. 지적사항, 개선권고사항
6. 그 외 특이사항

③ 감사보고서는 감사증거에 입각한 합리적 근거를 통하여 작성한다.

④ 작성된 보고서는 최고정보보호책임자에게 제출하며, 피 감사 부서장 및 기관장에게도 통보한다.

제12조 삭제 <2017.01.16>

제13조 (감사결과에 의한 업무개선)

① 정보보안 감사에서 지적된 사항은 해당 업무 담당자가 개선방안을 수립하도록 한다.

② 개선방안에는 조치사항과 그 결과 및 이행 일정 또는 시한이 명기되어야 한다.

③ 즉시 개선이 이루어지지 못한 사안의 사후관리로 감사담당자는 개선방안의 달성여부를 주기적으로 감사하며, 피 감사인은 지적 사항의 완전 해결 시점까지 그 이행 상황을 분기별로 정보보호실무책임자 및 정보보호위원회에 보고한다.

④ 감사인은 감사결과의 개선권고사항에 기초하여 경영자가 업무개선 명령을 시달한 사항에 대하여는 실시 경과 및 결과를 평가한다.

제14조 (시스템 감사도구에 대한 보호)

① 정보 시스템 감사 도구에 대한 접근은 있을 수 있는 오용 또는 손상을 방지하기 위하여 보호되어야 한다.

② 시스템 감사 도구, 즉 소프트웨어 또는 데이터 파일은 개발 및 운영 시스템으로부터

분리되어야 하며, 사용자 영역에 남겨두지 않아야 한다.

제15조 (시행과 갱신)

상기 지침서의 시행과 갱신을 위한 상세한 세부사항은 정보보호규정 '제4장 정보보호 정책'에 준한다.